



Instituto Politécnico Nacional
Escuela Superior de Cómputo
Ingeniería en Sistemas Computacionales



Gobierno de TI

Anexos

Alumnos:

Carol Monserrat Chávez Hernández

Alfredo Bautista Ríos

Diego Alejandro Moreno Martínez

Grupo: 7CV2

Profesora: Palacios Solano Rocío

Fecha de entrega: 05/01/2026

Anexos

Glosario

Concepto	Descripción
SAST (Static Application Security Testing)	Análisis de código fuente para identificar vulnerabilidades sin ejecutar la aplicación.
DAST (Dynamic Application Security Testing)	Pruebas de seguridad realizadas en tiempo de ejecución para detectar vulnerabilidades.
DevSecOps	Integración de prácticas de seguridad en el ciclo de vida de desarrollo de software.
XSS (Cross-Site Scripting)	Vulnerabilidad de seguridad en la cual un atacante inserta scripts maliciosos en aplicaciones web, que son ejecutados por los navegadores de los usuarios
Inyección SQL	Técnica de ataque que permite a un atacante ejecutar comandos SQL maliciosos en una base de datos, comprometiendo la integridad y confidencialidad de los datos.
API (Interfaz de Programación de Aplicaciones)	Conjunto de definiciones y protocolos que permiten la integración entre diferentes sistemas o aplicaciones. Las APIs mal implementadas pueden ser vulnerables a ataques.
Man in the Middle (MitM)	Tipo de ataque en el que un atacante intercepta y manipula la comunicación entre dos partes sin que ellas lo detecten, con el fin de robar o modificar la información transmitida.
CID (Confidencialidad, Integridad y Disponibilidad)	Triada que clasifica el impacto de un incidente: exposición de datos (C), alteración no autorizada (I) y pérdida de acceso (D).
BIA (Business Impact Analysis)	Análisis que identifica impactos al negocio por interrupciones y define prioridades y objetivos de recuperación.
MTD (Maximum Tolerable Downtime)	Tiempo máximo tolerable de interrupción antes de que el impacto sea inaceptable para el negocio.
RTO (Recovery Time Objective)	Tiempo objetivo para restaurar un proceso/servicio después de una interrupción.
RPO (Recovery Point Objective)	Antigüedad máxima tolerable de la información al recuperar (pérdida de datos permitida).

MTTR (Mean Time To Restore/Recover)	Tiempo promedio para restaurar un servicio tras una falla o incidente.
SLA (Service Level Agreement)	Compromiso medible de nivel de servicio acordado con el usuario/cliente del servicio.
OLA (Operational Level Agreement)	Acuerdo interno entre areas/proveedores internos que soportan el cumplimiento de un SLA.
SCA (Software Composition Analysis)	Analisis de dependencias y librerias de terceros para identificar vulnerabilidades y licencias de riesgo.
CVE (Common Vulnerabilities and Exposures)	Catalogo publico de identificadores para vulnerabilidades conocidas.
CVSS	Sistema estandar para puntuar severidad de vulnerabilidades (impacto y explotabilidad) en una escala numerica.
OWASP Top 10	Lista de riesgos mas comunes en aplicaciones web; se usa como referencia para priorizar controles y pruebas.
Hardening	Endurecimiento de configuracion para reducir superficie de ataque (servicios minimos, permisos, cifrado, politicas).
Gestion de parches (Patch management)	Proceso para evaluar, aprobar, desplegar y verificar parches de seguridad y actualizaciones.
WAF (Web Application Firewall)	Control perimetral que inspecciona trafico HTTP(S) y bloquea patrones de ataque hacia aplicaciones web.
Firewall	Control de red que filtra trafico segun reglas (puertos, protocolos, IPs) para limitar accesos no autorizados.
SIEM	Plataforma que centraliza logs, correlaciona eventos y genera alertas para deteccion y respuesta a incidentes.
IDS/IPS	Sistemas de deteccion/prevencion de intrusiones que identifican trafico malicioso y pueden bloquearlo.
EDR	Solucion de deteccion y respuesta en endpoints

	(equipos) para identificar comportamiento malicioso y contenerlo.
RBAC	Control de acceso basado en roles; asigna permisos segun funciones para aplicar minimo privilegio.
MFA	Autenticacion multifactor; reduce el riesgo de compromiso de cuentas aun si se filtra una contrasena.
Entorno de staging	Ambiente de preproduccion que replica condiciones de produccion para validar cambios y pruebas de seguridad.
Runbook	Guia operativa paso a paso para ejecutar tareas repetibles (p. ej., contencion, restauracion, despliegue).
Playbook de respuesta a incidentes	Procedimiento para un tipo de incidente (p. ej., XSS, credenciales comprometidas), con roles, decisiones y acciones.
DDoS	Ataque de denegacion de servicio distribuido que satura recursos para degradar o tumbar aplicaciones.
Retencion de logs	Politica de almacenamiento y preservacion de registros para auditoria y analisis forense.